



PENETRATION TESTING REPORT

WEBAPPLICATION& NETWORK MAPPING (NMAP) ASSESSMENT

**FOR
Internship Capstone Project**

8-12-2025 - 8-14-2025



Management Summary	2
Key Findings.....	2
Scope	3
Scope Overview.....	3
Type of Assessment	4
Approach.....	4
Framework.....	4
Severity Score Sheet	5
demo.testfire.net Summary.....	5
scanme.nmap.org Summary.....	6
Technical Analysis	8
Login Page Findings.....	8
Feedback Page.....	14
Transfer Funds Page.....	16
Nmap Findings	
Target: scanme.nmap.org	
Type of scans done:.....	20
Glossary	23
General Penetration Testing Terms.....	23
Severity Levels & Scoring.....	23
Tools & Frameworks.....	24
Web Application Vulnerabilities.....	24
Network Vulnerabilities.....	25
Attack Techniques.....	25
Security Controls & Recommendations.....	26

Management Summary

This penetration test report shows the result of a security assessment executed within a simulated enterprise environment during my risk management internship. The objective of this project is to practice and demonstrate the ability to identify potential security risks using a demo web application and network domain. Tools such as Nmap for network mapping, while Burp Suite for web application vulnerability assessment.

The assessment focused on identifying vulnerabilities that could affect the confidentiality, integrity, and availability of the system. Findings from this test highlight areas where the system may be exposed to unauthorized access, data interception, or financial loss, and recommendations to improve overall security.

Key Findings

Severity	Count (Web Application)	Count (Nmap)
HIGH	2	2
MEDIUM	3	2
LOW	0	0

Scope

Scope Overview

The goal of this penetration test is to evaluate the security of the target web applications, identify vulnerabilities, and provide recommendations for improving overall security. This test focuses on identifying security weaknesses that could be exploited by attackers, especially those that affect the confidentiality, integrity, and availability of the system.

1. Web Application - <http://demo.testfire.net/>

No.	Title	Link
1	Login Page	https://demo.testfire.net/login.jsp
2	Search News Articles Page	https://demo.testfire.net/bank/queryxpath.jsp?content=queryxpath.jsp&query=
3	Transfer Funds Page	https://demo.testfire.net/bank/transfer.jsp

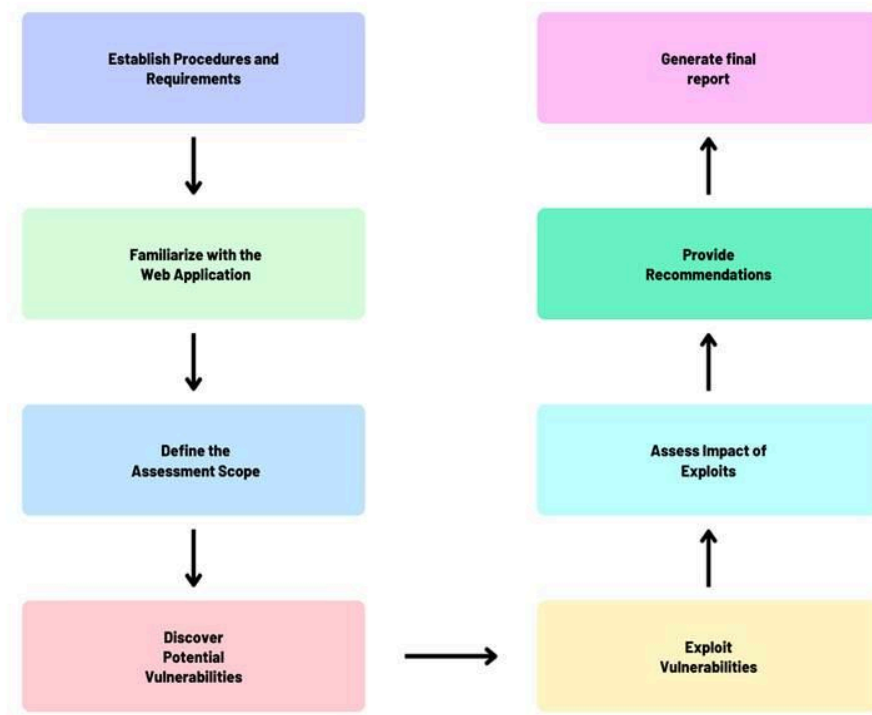
2. Nmap Scan

An Nmap scan was performed on the target domain scanme.nmap.org to identify open ports and services that could be potentially vulnerable to exploitation. The objective of this scan was to check the network and show exposed services that might be prone to an attack.

No.	Title	Link
1	Nmap Scan	scanme.nmap.org

Type of Assessment

Approach



Framework

- **OWASP Top 10** - for web application security vulnerabilities.
- **Owasp Web Security Testing Guide**

Severity Score Sheet

Severity	Score Range	Description
HIGH	27	Critical Issues with severe impact; requires immediate remediation.
MEDIUM	6-26	Moderate impact issues; remediation should be prioritized.
LOW	<6	Low impact issues; remediation can be scheduled as part of routine maintenance.

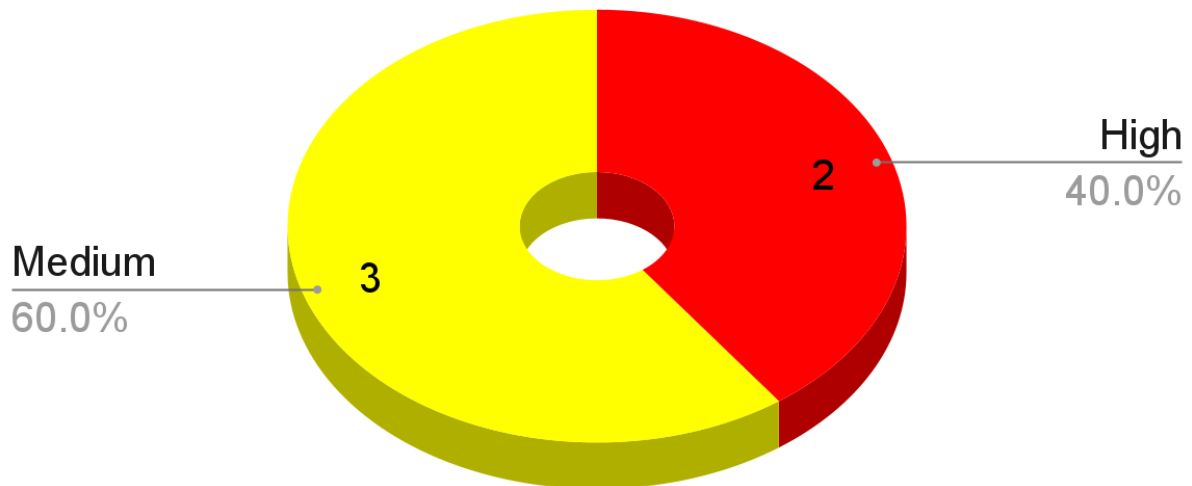
demo.testfire.net Summary

Area	Finding	Risk
Web Application	Default admin login	High
Web Application	SQL injection in login	High
Web Application	Credentials sent in plain text	Medium
Web Application	DOM XSS in search page	Medium
Web Application	Funds transfer tampering	Medium

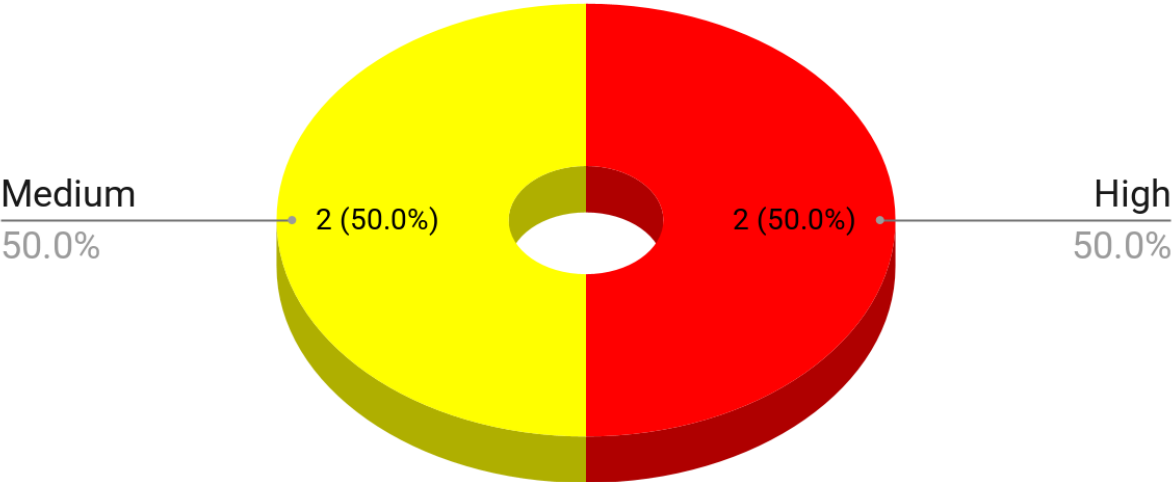
scanme.nmap.org Summary

Area	Finding	Risk
Nmap	HTTP unencrypted	High
Nmap	Suspicious Port: 31337	High
Nmap	SSH (Port: 22) brute force risk	Medium
Nmap	Nping Echo (9929) DoS risk	Medium

Web Application Severity Pie Chart



Nmap Severity Pie Chart



Technical Analysis

Login Page Findings

Finding #1: Allows Default Admin Credentials on Login Page

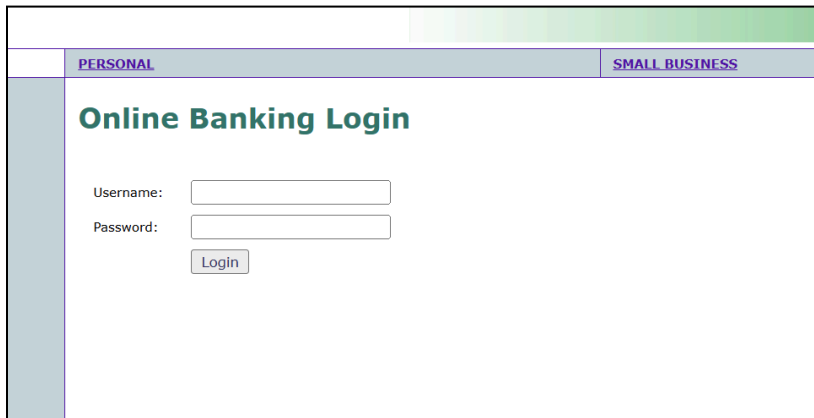
Risk Score: High (27) (Asset: 3, Impact: 3, Probability: 3)

Impact:

- Gain full administrative access to the system.
- Make unauthorized changes to application setting or data
- Expose sensitive user data or system information
- Potential full system compromise or takeover

Steps:

Step 1: Visit the login page <https://demo.testfire.net/login.jsp>



The screenshot shows a web application interface for online banking login. At the top, there is a navigation bar with two tabs: 'PERSONAL' and 'SMALL BUSINESS'. Below the navigation bar, the main heading is 'Online Banking Login'. The login form consists of two input fields: 'Username:' and 'Password:'. Below the password field is a 'Login' button. The page has a light blue sidebar on the left and a light green header bar at the top.

Step 2: Enter username and password as admin:admin values.

The screenshot shows a web browser window with a header bar containing the word "PERSONAL" on the left and a small "S" on the right. The main content area has the heading "Online Banking Login" in a large, bold, dark green font. Below the heading, there are two input fields: "Username:" with the text "admin" and "Password:" with five dots. A "Login" button is positioned below the password field.

Step 3: Click the login button then gain access to the Admin account.

The screenshot shows the "Hello Admin User" dashboard. The header bar has "PERSONAL" on the left and "SMA" on the right. The main content area features the heading "Hello Admin User" in a large, bold, dark green font. Below the heading, it says "Welcome to Altoro Mutual Online." and "View Account Details:" followed by a dropdown menu showing "800000 Corporate" and a "GO" button. A "Congratulations!" section follows, stating "You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!" and "Click [Here](#) to apply." The footer contains the text "ST API | © 2025 Altoro Mutual, Inc."

Recommendations:

- Change admin credentials into a more secure and unique credential.
- Disallow the use of default or common credentials.
- Enforce strict login security by implementing strong password policies.
- Consider implementing multi-factor authentication (MFA) for login security improvement.

Finding #2: Potential SQL injection - Input not sanitized in login page

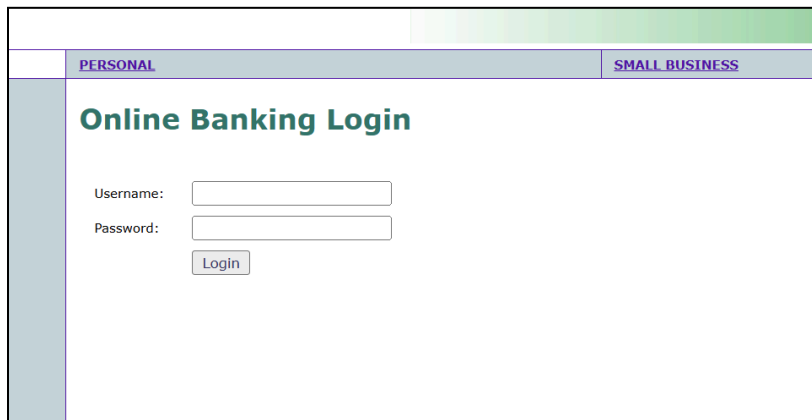
Risk Score: Medium (9) (Asset: 3, Impact: 1, Probability: 3)

Impact:

- An attacker can modify backend SQL queries
- Attempt login bypass by using injection techniques (' OR 1=1--)
- Potential access or manipulate sensitive authentication or users login related data

Steps:

Step 1: Visit the login page <https://demo.testfire.net/login.jsp>



PERSONAL SMALL BUSINESS

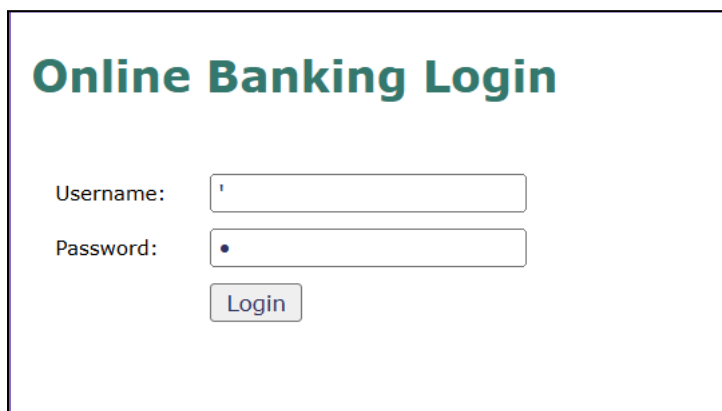
Online Banking Login

Username:

Password:

Login

Step 2: Enter the payload which is a single quote (') and type a random password



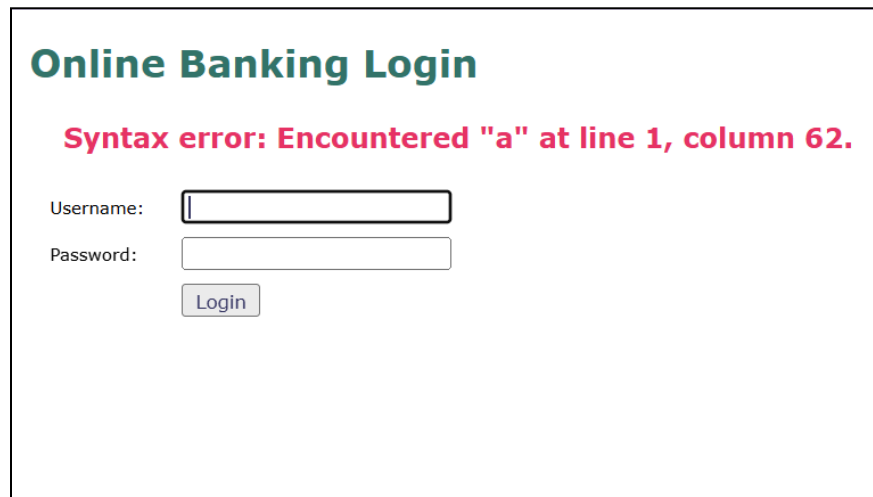
Online Banking Login

Username:

Password:

Login

Step 3: Press the login and a Syntax error shows.



The screenshot shows a web page titled "Online Banking Login". Below the title, a red error message reads: "Syntax error: Encountered 'a' at line 1, column 62." Below the error message, there are two input fields: "Username:" and "Password:". The "Username:" field is currently empty. Below the "Password:" field is a "Login" button.

Recommendations:

- Use parameterized queries to safely handle user input.
- Apply strict server-side input validation (Only allow valid characters (e.g. alphanumeric) in login fields.

Finding #3: Credentials sent Without Encryption

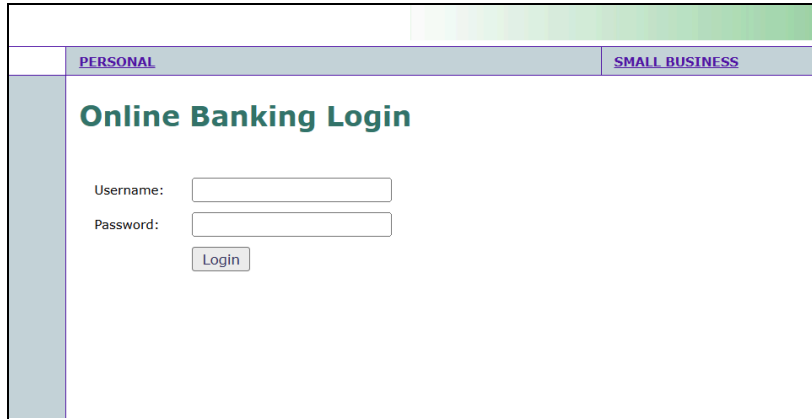
Risk Score: Medium (9) (Asset: 3, Impact: 3, Probability: 1)

Impact:

- Attackers can intercept usernames and passwords over the network.
- Credential theft, account compromise, and possible reuse on other systems.

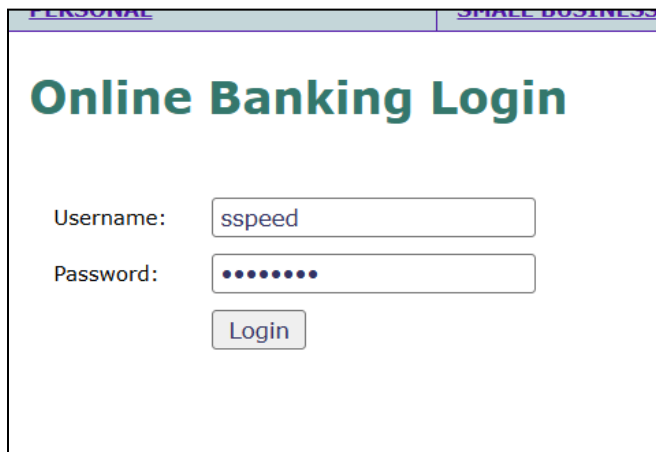
Steps:

Step 1: Visit the login page <https://demo.testfire.net/login.jsp>



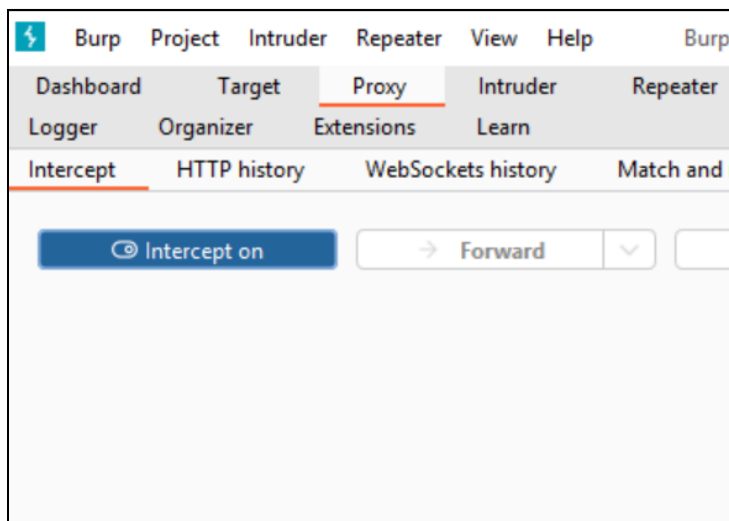
The screenshot shows a web browser window with a green header bar. Below the header, there are two tabs: "PERSONAL" (selected) and "SMALL BUSINESS". The main content area is titled "Online Banking Login". It contains two input fields: "Username:" and "Password:". Below the "Password:" field is a "Login" button.

Step 2: I entered valid user credentials (sspeed, Demo1234))



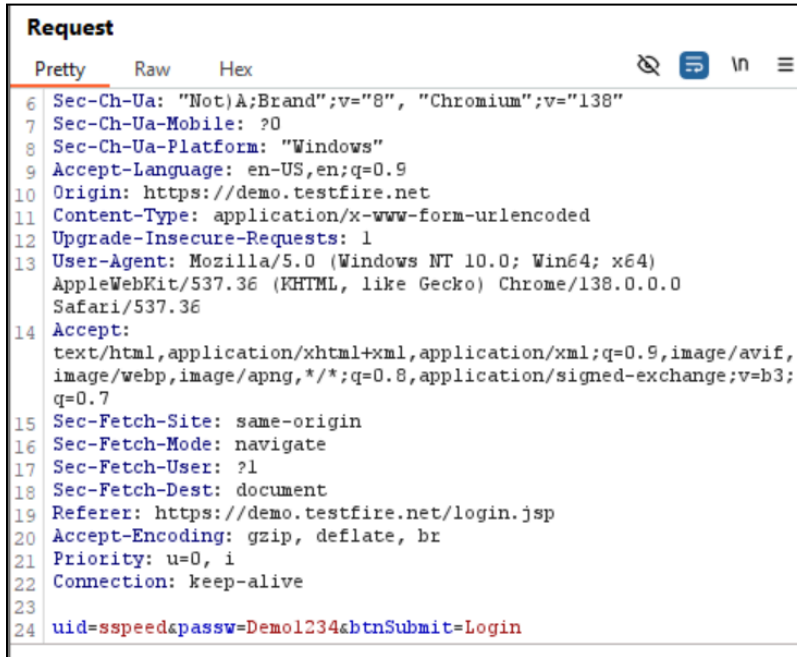
The screenshot shows the same "Online Banking Login" page. The "Username:" field now contains the text "sspeed". The "Password:" field contains ten black dots, representing the password "Demo1234". The "Login" button remains below the fields.

Step 3: Turn on Burp Suite intercept



Step 4: Click the login button and sign in

Step 5: Visit Burp Suite to see the request made



```
Request
Pretty Raw Hex
6 Sec-Ch-Ua: "Not)A;Brand";v="8", "Chromium";v="138"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://demo.testfire.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0
Safari/537.36
14 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,
image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;
q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://demo.testfire.net/login.jsp
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 uid=sspeed&passw=Demo1234&btnSubmit=Login
```

Step 6: Login credential is shown as “uid=sspeed&passw=Demo1234&btnSubmit=Login”

Recommendations:

- Use HTTPS for all pages, enforce HTTPS redirection.
- Enable HTTP Strict Transport Security (HSTS) to prevent downgrade to HTTP.
- Configure TLS securely (TLS 1.2+ only)

Feedback Page

Finding #1: Escaping HTML tag with DOM XSS Vulnerability in Search News Articles Page

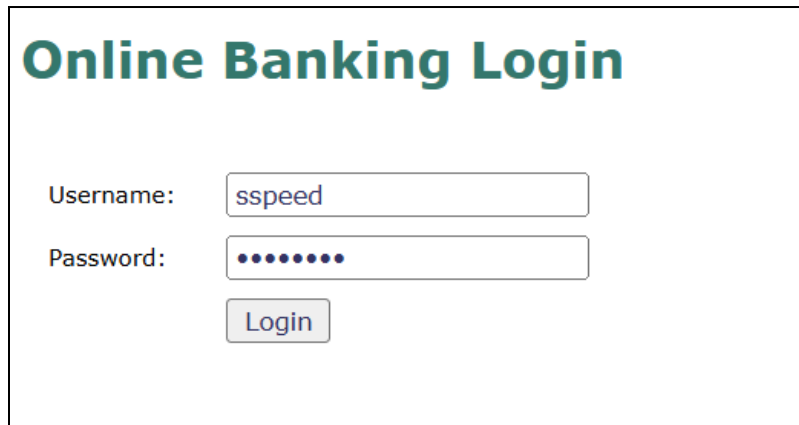
Risk Score: Medium (18) (Asset: 3, Impact: 3, Probability: 2)

Impact:

- Allows attacker-controlled JavaScript to run in a user's browser.
- Can steal session, alter page content, and redirect users to malicious sites
- Could lead to account compromise, data theft, or website defacement

Steps:

Step 1: Login as a user

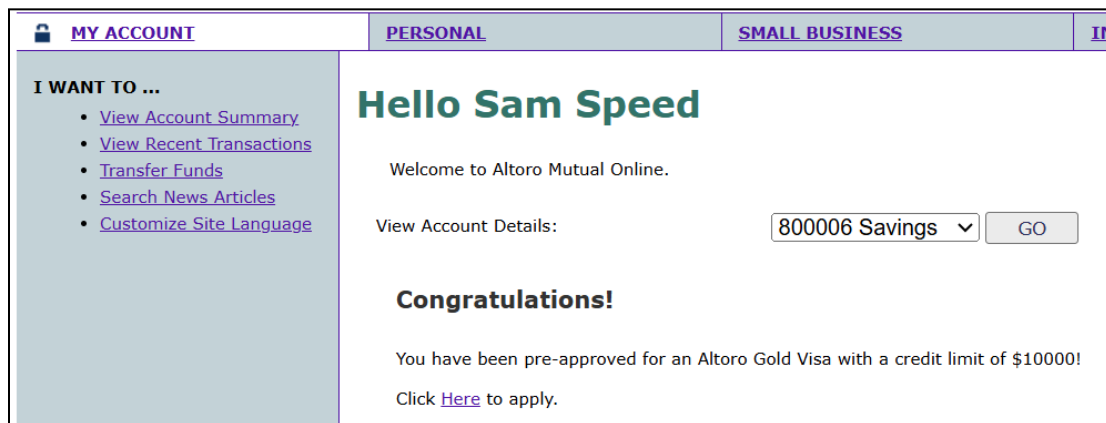


Online Banking Login

Username:

Password:

Step 2: Navigate through search news articles link



MY ACCOUNT PERSONAL SMALL BUSINESS IN

I WANT TO ...

- [View Account Summary](#)
- [View Recent Transactions](#)
- [Transfer Funds](#)
- [Search News Articles](#)
- [Customize Site Language](#)

Hello Sam Speed

Welcome to Altoro Mutual Online.

View Account Details:

Congratulations!

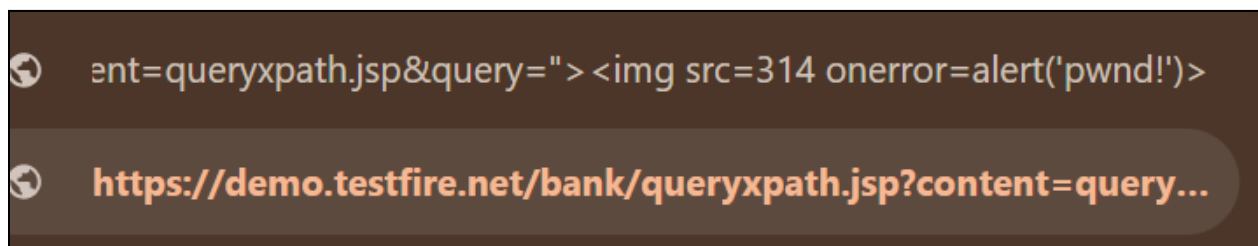
You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

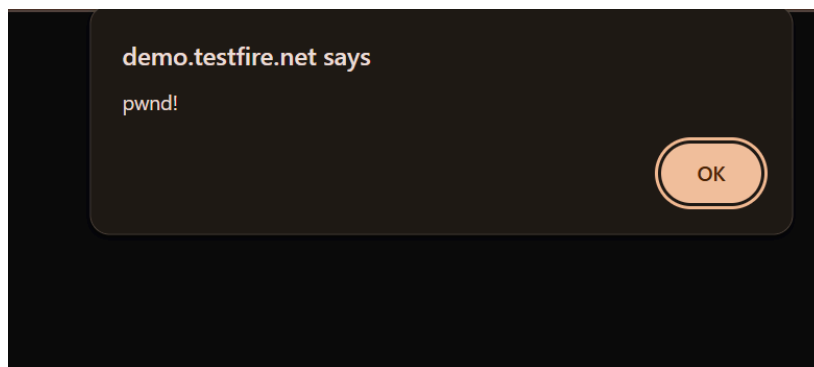
Step 3: Enter script in the query or enter in the URL ">



The screenshot shows a web application titled "Search News Articles". Below the title is the text "Search our news articles database". There is a search input field containing the payload "><img src=314 onerror=;" and a "Query" button to its right.



Step 4: Script activation on image error



Recommendations:

- Sanitize and encode all user inputs before inserting into the DOM
- Use safe DOM methods like `.textContent` instead of `.innerHTML`.

Transfer Funds Page

Finding #1: Exploitable Transfer Funds Function via Intercepted Requests

Risk Score: Medium (18) (Asset: 3, Impact: 3, Probability: 2)

Impact:

- Unauthorized transfers of funds to attacker-controlled accounts.
- Financial loss and theft for the organization or customers.
- Bypass of transaction limits or other financial controls.

Steps:

Step 1: Login as a user

Online Banking Login

Username:

Password:

Step 2: Navigate through the page and click transfer funds page

The screenshot shows the Altoro Mutual Online account page. At the top, there are navigation tabs: "MY ACCOUNT" (active), "PERSONAL", "SMALL BUSINESS", and "IN". Below "MY ACCOUNT", there is a section "I WANT TO ..." with links: "View Account Summary", "View Recent Transactions", "Transfer Funds", "Search News Articles", and "Customize Site Language". The main content area greets the user with "Hello Sam Speed" and "Welcome to Altoro Mutual Online." Below this, there is a "View Account Details:" section with a dropdown menu showing "800006 Savings" and a "GO" button. A "Congratulations!" message follows, stating: "You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000! Click [Here](#) to apply."

Step 3: Enter an amount to transfer.

The screenshot shows the "Transfer Funds" form. It has three main sections: "From Account:" with a dropdown menu showing "800006 Savings", "To Account:" with a dropdown menu showing "800007 Checking", and "Amount to Transfer:" with a text input field containing "60". Below these fields is a "Transfer Money" button.

Step 4: Turn on Burp Suite Intercept

The screenshot shows the Burp Suite interface. The "Intercept" tab is selected in the top navigation bar. Below the navigation bar, there is a section with a blue button labeled "Intercept on" and a "Forward" button with a dropdown arrow.

Step 5: Locate Request made

Request

PrettyRawHex

1

POST /bank/doTransfer HTTP/1.1

2

Host: demo.testfire.net

3

Cookie: JSESSIONID=FD5EB2587214D3BAFE55D7E2AD860034; AltoroAccounts="ODAwMDA2f1Nhdm1uZ3h+NC40NDkyMzQ4RTd8ODAwMDA3fkNoZWVraW5nfi00LjQzNTY1OTZFN3w="

4

Content-Length: 77

5

Cache-Control: max-age=0

6

Sec-Ch-Ua: "Not)A;Brand";v="8", "Chromium";v="138"

7

Sec-Ch-Ua-Mobile: ?0

8

Sec-Ch-Ua-Platform: "Windows"

9

Accept-Language: en-US,en;q=0.9

10

Origin: https://demo.testfire.net

11

Content-Type: application/x-www-form-urlencoded

12

Upgrade-Insecure-Requests: 1

13

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36

14

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15

Sec-Fetch-Site: same-origin

16

Sec-Fetch-Mode: navigate

17

Sec-Fetch-User: ?1

18

Sec-Fetch-Dest: document

19

Referer: https://demo.testfire.net/bank/doTransfer

20

Accept-Encoding: gzip, deflate, br

21

Priority: u=0, i

22

Connection: keep-alive

23

24

fromAccount=800006&toAccount=800007&transferAmount=60&transfer=Transfer+Money

Inspector

Request attributes2

Request query parameters0

Request body parameters4

Name	Value	
fromAccount	800006	>
toAccount	800007	>
transferAmount	60	>
transfer	Transfer Money	>

Request cookies2

Request headers21

Step 7: Change body parameter toAccount and transferAmount values to preferred values and amount (toAccount: 800003, transferAmount: 9999999)

Inspector

Request attributes2

Request query parameters0

Request body parameters4

Name	Value	
fromAccount	800006	>
toAccount	800003	>
transferAmount	9999999	>
transfer	Transfer Money	>

Request cookies2

Request headers21

```
23  
24 fromAccount=800006&toAccount=800003&transferAmount=9999999&transfer=  
Transfer+Money
```

Step 8: Forward request and get output

Transfer Funds

From Account:

800006 Savings ▾

To Account:

800006 Savings ▾

Amount to Transfer:

Transfer Money

9999999.0 was successfully transferred from Account 800006 into Account 800003 at 8/13/25 8:09 AM.

Recommendations:

- Implement server-side input validation for toAccount and transferAmount to ensure they are valid and belong to the logged-in user.
- Enforce server-side authorization checks to confirm the user can transfer funds to the specified account.
- Use hashing for sensitive request parameters to prevent tampering.
- Deploy a web application firewall (WAF) to detect and block manipulated requests.

Nmap Findings

Target: scanme.nmap.org

Type of scans done:

Type of Scan	Scan
Regular/Normal Scan	Nmap scanme.nmap.org
Quick Scan	Nmap -T4 -F scanme.nmap.org
UDP Scan	Nmap -sU scanme.nmap.org
Intense Scan	Nmap -T4 -A -v scanme.nmap.org
SYN scan all TCP ports	Nmap -sS -p- scanme.nmap.org

```
(kali㉿kali)-[~]
└─$ nmap -T4 -F scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-28 0
9:05 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.27s latency).
Other addresses for scanme.nmap.org (not scanned): 2600
:3c01::f03c:91ff:fe18:bb2f
Not shown: 97 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open       ssh
25/tcp    filtered  smtp
80/tcp    open       http

Nmap done: 1 IP address (1 host up) scanned in 2.39 sec
onds

(kali㉿kali)-[~]
└─$
```

```

(kali@kali)-[~]
└─$ nmap -T4 -F scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-28 0
9:05 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.27s latency).
Other addresses for scanme.nmap.org (not scanned): 2600
:3c01::f03c:91ff:fe18:bb2f
Not shown: 97 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open       ssh
25/tcp    filtered  smtp
80/tcp    open       http

Nmap done: 1 IP address (1 host up) scanned in 2.39 sec
onds

(kali@kali)-[~]

```

```

Not shown: 995 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
22/tcp    open       ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ac:10:a0:1a:02:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|_ 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a0:b2 (RSA)
|_ 256 96:02:bb:5e:57:5a:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_ 256 33:fa:91:0f:ee:e1:7b:1f:0d:05:a2:b0:f1:54:41:56 (ED25519)
25/tcp    filtered  smtp
80/tcp    open       http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-favicon: Nmap Project
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.7 ((Ubuntu))
9929/tcp  open       nping-echo   Nping echo
51337/tcp open       tcpwrapped
Aggressive OS guesses: Linux 4.19 - 5.15 (98%), Linux 4.15 (95%), IPFire 2.27 (Linux 5.15 - 6.1) (94%), Linux 5.4 (94%), Linux
91%, Linux 3.11 - 4.9 (91%), Linux 3.2 - 3.8 (91%), Linux 2.6.32 (91%), Android TV OS 11 (Linux 4.19) (90%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 32.403 days (since Tue Jun 24 23:50:19 2025)
Network Distance: 10 hops
TCP Sequence Prediction: Difficulty=258 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 587/tcp)
HOP RTT      ADDRESS
1  0.39 ms  elifeconnect (192.168.1.1)
2  13.26 ms bba-94-59-84-1.alshamil.net.ae (94.59.84.1)
3  13.26 ms 10.246.255.29
4  16.45 ms 194.170.186.168
5  272.76 ms 195.229.0.149
6  ... 9
10 276.72 ms scanme.nmap.org (45.33.32.156)

```

```

(kali@kali)-[~]
└─$ nmap -sS -p- scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-28 09:10 EDT
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.35% done
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.96% done
Stats: 0:02:45 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 27.02% done; ETC: 09:20 (0:07:26 remaining)
Verbosity Increased to 1.
SYN Stealth Scan Timing: About 94.26% done; ETC: 09:20 (0:00:36 remaining)
Completed SYN Stealth Scan at 09:21, 648.50s elapsed (65535 total ports)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.27s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 65530 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open       ssh
25/tcp    filtered  smtp
80/tcp    open       http
9929/tcp  open       nping-echo
51337/tcp open       Elite

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 648.92 seconds
Raw packets sent: 67439 (2.967MB) | Rcvd: 68139 (2.750MB)

```

Ports and Services:

Port	Port Status	Service	Impact
22/TCP	Open	SSH, Secure Shell	Risk of brute-force attacks if weak passwords are used.
80/TCP	Open	HTTP. Hypertext Transfer Protocol	Traffic is unencrypted, vulnerable to web-based attacks.
9929/TCP	Open	Nping-echo	Could be abused for network reflection or DoS if misconfigured
31337/TCP	Open	Elite	Often associated with backdoors. Could allow unauthorized access
25/TCP	Filtered	SMTP	Filtered but may be vulnerable to spam relay or brute force attacks if opened.

Glossary

General Penetration Testing Terms

- Penetration Test (Pentest) – A simulated cyberattack against a system to find and fix security weaknesses.
- Security Assessment – A review of a system's security posture, including vulnerabilities and risks.
- Confidentiality – Ensuring that sensitive information is only accessible to authorized users.
- Integrity – Guaranteeing that data is accurate and has not been altered without authorization.
- Availability – Ensuring that systems and data are accessible to authorized users when needed.
- Vulnerability – A flaw or weakness in a system that could be exploited by an attacker.
- Risk Score – A numerical representation of the potential impact and likelihood of a vulnerability being exploited.
- Asset – Any resource (hardware, software, or data) that has value and needs protection.
- Impact – The potential damage or consequences if a vulnerability is exploited.
- Probability – The likelihood that a vulnerability will be exploited.

Severity Levels & Scoring

- High Severity (Score 27) – Critical issues requiring immediate action.
- Medium Severity (Score 6–26) – Moderate issues that should be fixed soon.
- Low Severity (Score <6) – Minor issues that can be fixed as part of routine maintenance.

Tools & Frameworks

- Nmap (Network Mapper) – A network scanning tool used to discover devices, open ports, and services on a network.
- Burp Suite – A web application security testing tool used for intercepting and modifying HTTP requests and responses.
- OWASP Top 10 – A list of the ten most critical web application security risks, maintained by the Open Web Application Security Project.
- OWASP Web Security Testing Guide (WSTG) – A framework for testing the security of web applications.

Web Application Vulnerabilities

- Default Credentials – Pre-set usernames and passwords (e.g., admin/admin) that attackers can guess easily.
- SQL Injection (SQLi) – A vulnerability where malicious SQL code is inserted into a query to manipulate a database.
- Plaintext Credentials – Usernames and passwords sent without encryption, allowing attackers to intercept them.
- DOM XSS (Document Object Model Cross-Site Scripting) – A type of XSS where malicious scripts are executed in the user's browser due to unsafe handling of user input in JavaScript.
- Funds Transfer Tampering – Manipulating financial transaction requests to steal or transfer money.

Network Vulnerabilities

- Open Port – A network port that is accepting connections, which could be exploited if associated services are insecure.
- SSH (Port 22) – A secure protocol for remote login; vulnerable to brute-force attacks if passwords are weak.
- HTTP (Port 80) – Unencrypted web traffic, vulnerable to interception and man-in-the-middle attacks.
- Nping Echo (Port 9929) – A diagnostic service that could be exploited for denial-of-service (DoS) attacks.
- Port 31337 ("Elite") – Often linked to backdoors or malicious remote access tools.
- SMTP (Port 25) – Email sending protocol; could be abused for spam or phishing if not secured.

Attack Techniques

- Brute-Force Attack – Trying multiple passwords until the correct one is found.
 - Interception (Man-in-the-Middle) – Capturing network traffic to steal sensitive data.
 - Parameter Tampering – Modifying data in requests (such as account numbers or transfer amounts) to bypass restrictions.
- Cross-Site Scripting (XSS) – Injecting malicious scripts into a web page viewed by other users.
- Denial of Service (DoS) – Overloading a service to make it unavailable to legitimate users.
 - Backdoor Access – Hidden access to a system, bypassing normal authentication.

Security Controls & Recommendations

- Server-Side Validation – Checking and filtering user input on the server before processing it.
- Parameterized Queries – SQL queries that use placeholders to safely handle user input.
- HTTPS – Secure web traffic using encryption (TLS).
- HSTS (HTTP Strict Transport Security) – A mechanism that forces browsers to use HTTPS only.
- Multi-Factor Authentication (MFA) – A login security method requiring two or more verification factors.
- Web Application Firewall (WAF) – A security tool that filters and blocks malicious web requests.
- TLS (Transport Layer Security) – A protocol for encrypting communications between clients and servers.

